

NIST SP 800-171 Rev 3 control 03.15.03 (03.15.03 Rules of Behavior) is assessed by examining the following: Assessment Objectives: - rules that describe responsibilities and expected behavior for system usage and protecting CUI are established. - rules are provided to individuals who require access to the system. - a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior is received before authorizing access to CUI and the system. - the rules of behavior are updated [organization-defined parameter] . - the rules of behavior are reviewed [organization-defined parameter].

NIST SP 800-171 Rev 3 control 03.15.03 (03.15.03 Rules of Behavior) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Planning (PL) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.15.03 (03.15.03 Rules of Behavior) falls under the Planning family. Control Statement: SR-03.15.03.a Establish rules that describe the responsibilities and expected behavior for system usage and protecting CUI. SR-03.15.03.b Provide rules to individuals who require access to the system. SR-03.15.03.c Receive a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior before authorizing access to CUI and the system. SR-03.15.03.d Review and update the rules of behavior [organization-defined parameter]. Supplemental Guidance: Rules of behavior represent a type of access agreement for system users. Organizations consider rules of behavior for the handling of CUI based on individual user roles and responsibilities and differentiate between rules that apply to privileged users and rules that apply to general users.

PL-8.1 · Defense in Depth Control Statement: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined parameter] to [organization-defined parameter] ; and (b) Ensures that the allocated controls operate in a coordinated and mutually reinforcing manner. Supplemental Guidance: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined parameter] to [organization-defined parameter] ; and (b) Ensures that the allocated controls operate in a coordinated and mutually reinforcing manner. Organizations strategically allocate security and privacy controls in the security and privacy architectures so that adversaries must overcome multiple controls to achieve their objective. Requiring adversaries to defeat multiple controls makes it more difficult to attack information resources by increasing the work factor of the adversary; it also increases the likelihood of detection. The coordination of allocated controls is essential to ensure that an attack that involves one control does not create adverse, unintended consequences by interfering with other controls. Unintended consequences can include system lockout and cascading alarms. The placement of controls in systems and organizations is an important activity that requires thoughtful analysis. The value of organizational assets is an important consideration in providing additional layering. Defense-in-depth architectural approaches include modularity and layering (see [SA-8(3)](#sa-8.3) ), separation of system and user functionality (see [SC-2](#sc-2) ), and security function isolation (see [SC-3](#sc-3)).

Under the FedRAMP Moderate baseline, PL-2 (PL-2 System Security and Privacy Plans): FedRAMP Moderate Baseline · PL-2 · System Security and Privacy Plans Control Statement: a. Develop security and privacy plans for the system that: 1. Are consistent with the organization's enterprise architecture; 2. Explicitly define the constituent system components; 3. Describe the operational context of the system in terms of mission and business processes; 4. Identify the individuals that fulfill system roles and responsibilities; 5. Identify the information types processed, stor

Under the FedRAMP High baseline, PL-1 (PL-1 Policy and Procedures): FedRAMP High Baseline · PL-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] planning policy that: 2. Procedures to facilitate the implementation of the planning policy and the associated planning controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the planning policy and procedures; and c. Review and update the curr

NIST SP 800-53 Rev 5 control PL-9 (Central Management) is assessed by examining, interviewing, and testing: PL-9 · Central Management Control Statement: Centrally manage [organization-defined parameter]. Supplemental Guidance: Centrally manage [organization-defined parameter]. Central

management refers to organization-wide management and implementation of selected controls and processes. This includes planning, implementing, assessing, authorizing, and monitoring the organization-defined, centrally managed controls and processes. As the central management of controls is generally associated with the

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: PL-02 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.15.02.b [Assignment: organization-defined frequency] at least every 12 months, or when there are significant incidents or significant changes to risks Planning 3.15.3 Rules of Behavior a. Establish rules that describe the responsibilities and expected behavior for system usage and protecting CUI. b. Provide rules to individuals who require access to the system. c. Receive a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior before authorizing access to CUI and the system. d. Review and update the rules of behavior [Assignment: organization-defined frequency] (03.15.03.d). Related Controls: PL-04 ODP Values

when the rules are revised or updated]. Discussion: Rules of behavior represent a type of access agreement for organizational users. Other types of access agreements include nondisclosure agreements, conflict-of-interest agreements, and acceptable use agreements (see PS-6). Organizations consider rules of behavior based on individual user roles and responsibilities and differentiate between rules that apply to privileged users and rules that apply to general users. Establishing rules of behavior for some types of non-organizational users, including individuals who receive information from federal systems, is often not feasible given the large number of such users and the limited nature of their interactions with the systems. Rules of behavior for organizational and non-organizational users can also be established in AC-8. The related controls section provides a list of controls that are relevant to organizational rules of behavior. PL-4b, the documented acknowledgment portion of the control, may be satisfied by the literacy training and awareness and role-based training programs conducted by organizations if such training includes rules of behavior.

Under the FedRAMP Low baseline, PL-10 (PL-10 Baseline Selection): FedRAMP Low Baseline · PL-10 · Baseline Selection Control Statement: Select a control baseline for the system. Supplemental Guidance: Select a control baseline for the system. Control baselines are predefined sets of controls specifically assembled to address the protection needs of a group, organization, or community of interest. Controls are chosen for baselines to either satisfy mandates imposed by laws, executive orders, directives, regulations, policies, standards, and guidelines or address

NIST SP 800-171 Rev 3 control 03.15.03 (03.15.03 Rules of Behavior) requires organizations to implement the following: Control Statement: SR-03.15.03.a Establish rules that describe the responsibilities and expected behavior for system usage and protecting CUI. SR-03.15.03.b Provide rules to individuals who require access to the system. SR-03.15.03.c Receive a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior before authorizing access to CUI and the system. SR-03.15.03.d Review and update the rules of behavior [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.15.03.

NIST SP 800-53 Rev 5 control PL-11 (Baseline Tailoring) is assessed by examining, interviewing, and testing: PL-11 · Baseline Tailoring Control Statement: Tailor the selected control baseline by applying specified tailoring actions. Supplemental Guidance: Tailor the selected control baseline by applying specified tailoring actions. The concept of tailoring allows organizations to specialize or customize a set of baseline controls by applying a defined set of tailoring actions. Tailoring actions facilitate such specialization and customization by allowing organizations to develop security and privacy

NIST SP 800-171 Rev 3 control 03.15.01 (03.15.01 Policy and Procedures) is assessed by examining the following: Assessment Objectives: - policies needed to satisfy the security requirements for the protection of CUI are developed and documented. - policies needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles. - procedures needed to satisfy the security requirements for the protection of CUI are developed and documented. - procedures needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles. - policies and procedures are reviewed

[organization-defined parameter]. - poli

NIST SP 800-53 Rev 5 control PL-10 (Baseline Selection) is assessed by examining, interviewing, and testing: PL-10 · Baseline Selection Control Statement: Select a control baseline for the system. Supplemental Guidance: Select a control baseline for the system. Control baselines are predefined sets of controls specifically assembled to address the protection needs of a group, organization, or community of interest. Controls are chosen for baselines to either satisfy mandates imposed by laws, executive orders, directives, regulations, policies, standards, and guidelines or address threats common to all

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: PL-04 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.15.03.d [Assignment: organization-defined frequency] at least every 12 months, or when there are significant incidents or significant changes to risks System and Services Acquisition 3.16.1 Systems Security Engineering Principles Apply the following systems security engineering principles to the development or modification of the system and system components: [Assignment: organization-defined systems security engineering principles] (03.16.01). Related Controls: SA-08 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.16.01 [Assignment: organization-defined systems security engineering principles] Guidance: At a minimum, documentation that provides user and administrator

NIST SP 800-171 Rev 3 control 03.15.02 (03.15.02 System Security Plan) is assessed by examining the following: Assessment Objectives: - a system security plan that defines the constituent system components is developed. - a system security plan that identifies the information types processed, stored, and transmitted by the system is developed. - a system security plan that describes specific threats to the system that are of concern to the organization is developed. - a system security plan that describes the operational environment for the system and any dependencies on or connections to other systems or system components is developed. - a system security plan that provides an overview of the security

Under the FedRAMP High baseline, PL-4.1 (PL-4.1 Social Media and External Site/Application Usage Restrictions): FedRAMP High Baseline · PL-4.1 · Social Media and External Site/Application Usage Restrictions Control Statement: Include in the rules of behavior, restrictions on: (a) Use of social media, social networking sites, and external sites/applications; (b) Posting organizational information on public websites; and (c) Use of organization-provided identifiers (e.g., email addresses) and authentication secrets (e.g., passwords) for creating accounts on external sites/applications. Supplemental Guidance

Under the FedRAMP Moderate baseline, PL-4 (PL-4 Rules of Behavior): FedRAMP Moderate Baseline · PL-4 · Rules of Behavior Control Statement: a. Establish and provide to individuals requiring access to the system, the rules that describe their responsibilities and expected behavior for information and system usage, security, and privacy; b. Receive a documented acknowledgment from such individuals, indicating that they have read, understand, and agree to abide by the rules of behavior, before authorizing access to information and the system; c. Review and update

NIST SP 800-53 Rev 5 control PL-8 (Security and Privacy Architectures) summarizes the requirements for this control: PL-8 · Security and Privacy Architectures Control Statement: a. Develop security and privacy architectures for the system that: 1. Describe the requirements and approach to be taken for protecting the confidentiality, integrity, and availability of organizational information; 2. Describe the requirements and approach to be taken for processing personally identifiable information to minimize privacy risk to individuals; 3. Describe how the architectures are integrated into and support the

NIST SP 800-171 Rev 3 control 03.15.01 (03.15.01 Policy and Procedures) falls under the Planning family. Control Statement: SR-03.15.01.a Develop, document, and disseminate to organizational personnel or roles the policies and procedures needed to satisfy the security requirements for the protection of CUI. SR-03.15.01.b Review and update policies and procedures [organization-defined parameter]. Supplemental Guidance: This requirement addresses policies and procedures for the protection of CUI. Policies and procedures contribute to security assurance and should address each family of the CUI security requirements. Policies can be included as part of the organizational security policy or be represented by separate policies that address each family of security

requirements. Procedures describe how policies are implemented and can be directed at the individual or role that is the object of

Control PL-11: BASELINE TAILORING Control: Tailor the selected control baseline by applying specified tailoring actions. Discussion: The concept of tailoring allows organizations to specialize or customize a set of baseline controls by applying a defined set of tailoring actions. Tailoring actions facilitate such specialization and customization by allowing organizations to develop security and privacy plans that reflect their specific mission and business functions, the environments where their systems operate, the threats and vulnerabilities that can affect their systems, and any other conditions or situations that can impact their mission or business success. Tailoring guidance is provided in [SP 800-53B]. Tailoring a control baseline is accomplished by identifying and designating common controls, applying scoping considerations, selecting compensating controls, assigning values to control parameters, supplementing the control baseline with additional controls as needed, and providing information for control implementation. The general tailoring actions in [SP 800-53B] can be supplemented with additional actions based on the needs of organizations. Tailoring actions can be applied to the baselines in [SP 800-53B] in accordance with the security and privacy requirements from [FISMA], [PRIVACT], and [OMB A-130]. Alternatively, other communities of interest adopting different control baselines can apply the tailoring actions in [SP 800-53B] to specialize or customize the controls that represent the specific needs and concerns of those entities. CHAPTER THREE PAGE 201 NIST SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

---

Related Controls: PL-10, RA-2, RA-3, RA-9, SA-8. Control Enhancements: None.

NIST SP 800-53 Rev 5 control PL-2 (System Security and Privacy Plans) summarizes the requirements for this control: PL-2 · System Security and Privacy Plans Control Statement: a. Develop security and privacy plans for the system that: 1. Are consistent with the organization's enterprise architecture; 2. Explicitly define the constituent system components; 3. Describe the operational context of the system in terms of mission and business processes; 4. Identify the individuals that fulfill system roles and responsibilities; 5. Identify the information types processed, stored, and transmitted by the s

Under the FedRAMP Low baseline, PL-8 (PL-8 Security and Privacy Architectures): FedRAMP Low Baseline · PL-8 · Security and Privacy Architectures Control Statement: a. Develop security and privacy architectures for the system that: 1. Describe the requirements and approach to be taken for protecting the confidentiality, integrity, and availability of organizational information; 2. Describe the requirements and approach to be taken for processing personally identifiable information to minimize privacy risk to individuals; 3. Describe how the architectures are integrate

Under the FedRAMP Moderate baseline, PL-11 (PL-11 Baseline Tailoring): FedRAMP Moderate Baseline · PL-11 · Baseline Tailoring Control Statement: Tailor the selected control baseline by applying specified tailoring actions. Supplemental Guidance: Tailor the selected control baseline by applying specified tailoring actions. The concept of tailoring allows organizations to specialize or customize a set of baseline controls by applying a defined set of tailoring actions. Tailoring actions facilitate such specialization and customization by allowing organizations to d

NIST SP 800-171 Rev 3 control 03.15.02 (03.15.02 System Security Plan) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Planning (PL) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control PL-1 (Policy and Procedures) is assessed by examining, interviewing, and testing: PL-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] planning policy that: 2. Procedures to facilitate the implementation of the planning policy and the associated planning controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the planning policy and procedures; and c. Review and update the current planning: 1. Policy

NIST SP 800-53 Rev 5 control PL-4 (Rules of Behavior) summarizes the requirements for this control: PL-4 · Rules of Behavior Control Statement: a. Establish and provide to individuals requiring access to the system, the rules that describe their responsibilities and expected behavior for information and system usage, security, and privacy; b. Receive a documented acknowledgment from such individuals, indicating that they have read, understand, and agree to abide by the rules of behavior, before authorizing access to information and the system; c. Review and update the rules of behavior [organ

Under the FedRAMP High baseline, PL-10 (PL-10 Baseline Selection): FedRAMP High Baseline · PL-10 · Baseline Selection Control Statement: Select a control baseline for the system. Supplemental Guidance: Select a control baseline for the system. Control baselines are predefined sets of controls specifically assembled to address the protection needs of a group, organization, or community of interest. Controls are chosen for baselines to either satisfy mandates imposed by laws, executive orders, directives, regulations, policies, standards, and guidelines or addr

Under the FedRAMP Low baseline, PL-1 (PL-1 Policy and Procedures): FedRAMP Low Baseline · PL-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] planning policy that: 2. Procedures to facilitate the implementation of the planning policy and the associated planning controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the planning policy and procedures; and c. Review and update the curre

Related Controls: PL-04 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.15.03.d [Assignment: organization- defined frequency] at least every 12 months, or when there are significant1 incidents or significant1 changes to risks System and Services Acquisition 3.16.1 Systems Security Engineering Principles Apply the following systems security engineering principles to the development or modification of the system and system components: [Assignment: organization-defined systems security engineering principles] (03.16.01). Related Controls: SA-08 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.16.01 [Assignment: organization-defined systems security engineering principles] Guidance: At a minimum, documentation that provides user and administrator guidance for the implementation and operation of controls. The level of detail required in such documentation should be based on the degree to which organizations depend on the capabilities, functions, or mechanisms to meet risk response expectations. Requirements can include mandated configuration settings that specify allowed functions, ports, protocols, and services. Acceptance criteria for systems, system components, and system services are defined in the same manner as the criteria for any organizational acquisition or procurement.

NIST SP 800-171 Rev 3 control 03.15.02 (03.15.02 System Security Plan) falls under the Planning family. Control Statement: SR-03.15.02.a Develop a system security plan that: SR-03.15.02.a.01 Defines the constituent system components; SR-03.15.02.a.02 Identifies the information types processed, stored, and transmitted by the system; SR-03.15.02.a.03 Describes specific threats to the system that are of concern to the organization; SR-03.15.02.a.04 Describes the operational environment for the system and any dependencies on or connections to other systems or system components; SR-03.15.02.a.05 Provides an overview of the security requirements for the system; SR-03.15.02.a.06 Describes the safeguards in place or planned for meeting the security requirements; SR-03.15.02.a.07 Identifies individuals that fulfill system roles and responsibilities; and SR-03.15.02.a.08 Includes other relevant information necessary for the protection of CUI. SR-03.15.02.b Review and update the system security plan [organization-defined parameter]. SR-03.15.02.c Protect the system security plan from unauthorized disclosure. Supplemental Guidance: System security plans provide key characteristics of the system that is processing, storing, and transmitting CUI and how the system and information are protected. System security plans contain sufficient information to enable a design and implementation that are unambiguously compliant with the intent of the plans and the subsequent determinations of risk if the plan is implemented as intended. System security plans can be a collection of documents, including documents th

Under the FedRAMP High baseline, PL-4 (PL-4 Rules of Behavior): FedRAMP High Baseline · PL-4 · Rules of Behavior Control Statement: a. Establish and provide to individuals requiring access to the system, the rules that describe their responsibilities and expected behavior for information and system usage, security, and privacy; b. Receive a documented acknowledgment from such individuals,

indicating that they have read, understand, and agree to abide by the rules of behavior, before authorizing access to information and the system; c. Review and update the

NIST SP 800-53 Rev 5 control PL-4 (Rules of Behavior): PL-4 · Rules of Behavior Control Statement:

a. Establish and provide to individuals requiring access to the system, the rules that describe their responsibilities and expected behavior for information and system usage, security, and privacy; b. Receive a documented acknowledgment from such individuals, indicating that they have read, understand, and agree to abide by the rules of behavior, before

NIST SP 800-171 Rev 3 control 03.15.01 (03.15.01 Policy and Procedures) requires organizations to implement the following: Control Statement: SR-03.15.01.a Develop, document, and disseminate to organizational personnel or roles the policies and procedures needed to satisfy the security requirements for the protection of CUI. SR-03.15.01.b Review and update policies and procedures [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.15.01.

Under the FedRAMP Low baseline, PL-2 (PL-2 System Security and Privacy Plans): FedRAMP Low Baseline · PL-2 · System Security and Privacy Plans Control Statement: a. Develop security and privacy plans for the system that: 1. Are consistent with the organization's enterprise architecture; 2. Explicitly define the constituent system components; 3. Describe the operational context of the system in terms of mission and business processes; 4. Identify the individuals that fulfill system roles and responsibilities; 5. Identify the information types processed, stored, a

NIST SP 800-171 Rev 3 control 03.15.01 (03.15.01 Policy and Procedures) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Planning (PL) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control PL-11 (Baseline Tailoring) summarizes the requirements for this control: PL-11 · Baseline Tailoring Control Statement: Tailor the selected control baseline by applying specified tailoring actions. Supplemental Guidance: Tailor the selected control baseline by applying specified tailoring actions. The concept of tailoring allows organizations to specialize or customize a set of baseline controls by applying a defined set of tailoring actions. Tailoring actions facilitate such specialization and customization by allowing organizations to develop security and privacy

03.15.02 · System Security Plan Control Statement: SR-03.15.02.a Develop a system security plan that: SR-03.15.02.a.01 Defines the constituent system components; SR-03.15.02.a.02 Identifies the information types processed, stored, and transmitted by the system; SR-03.15.02.a.03 Describes specific threats to the system that are of concern to the organization; SR-03.15.02.a.04 Describes the operational environment for the system and any dependencies on or connections to other systems or system components; SR-03.15.02.a.05 Provides an overview of the security requirements for the system; SR-03.15.02.a.06 Describes the safeguards in place or planned for meeting the security requirements; SR-03.15.02.a.07 Identifies individuals that fulfill system roles and responsibilities; and SR-03.15.02.a.08 Includes other relevant information necessary for the protection of CUI. SR-03.15.02.b Review and update the system security plan [organization-defined parameter]. SR-03.15.02.c Protect the system security plan from unauthorized disclosure. Supplemental Guidance: System security plans provide key characteristics of the system that is processing, storing, and transmitting CUI and how the system and information are protected. System security plans contain sufficient information to enable a design and implementation that are unambiguously compliant with the intent of the plans and the subsequent determinations of risk if the plan is implemented as intended. System security plans can be a collection of documents, including documents that already exist. Effective system security plans reference policies, procedures, and documents (e.g., design specifications) that provide additional detailed information. This reduces the documentation requirements associated with security programs and maintains security information in other established management or operational areas related to enterprise architecture, the system development life cycle, systems engineering, and acquisition. Assessment Objectives: - a system security plan that defines the constituent system components is

developed. - a system security plan that identifies the information types processed, stored, and transmitted by the system is developed. - a system security plan that describes specific threats to the system that are of concern to the organization is developed. - a system security plan that describes the operational environment for the system and any dependencies on or connections to other systems or system components is developed. - a system security plan that provides an overview of the security requirements for the system is developed. - a system security plan that describes the safeguards in place or planned for meeting the security requirements is developed. - a system security plan that identifies individuals that fulfill system roles and responsibilities is developed. - a system security plan that includes other relevant information necessary for the protection of CUI is developed. - the system security plan is reviewed [organization-defined parameter]. - the system security plan is updated [organization-defined parameter]. - the system security plan is protected from unauthorized disclosure. Organization-Defined Parameters: - A.03.15.02.ODP.01: frequency

NIST SP 800-53 Rev 5 control PL-8.1 (Defense in Depth) is assessed by examining, interviewing, and testing: PL-8.1 · Defense in Depth Control Statement: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined parameter] to [organization-defined parameter] ; and (b) Ensures that the allocated controls operate in a coordinated and mutually reinforcing manner. Supplemental Guidance: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined param

NIST SP 800-171 Rev 3 control 03.15.01 (03.15.01 Policy and Procedures) is assessed by examining the following: Assessment Objectives: - policies needed to satisfy the security requirements for the protection of CUI are developed and documented. - policies needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles. - procedures needed to satisfy the security requirements for the protection of CUI are developed and documented. - procedures needed to satisfy the security requirements for the protection of CUI are disseminated to organizational personnel or roles. - policies and procedures are reviewed [organization-defined parameter]. - poli

NIST SP 800-171 Rev 3 control 03.15.03 (03.15.03 Rules of Behavior) is assessed by examining the following: Assessment Objectives: - rules that describe responsibilities and expected behavior for system usage and protecting CUI are established. - rules are provided to individuals who require access to the system. - a documented acknowledgement from individuals indicating that they have read, understand, and agree to abide by the rules of behavior is received before authorizing access to CUI and the system. - the rules of behavior are updated [organization-defined parameter] . - the rules of behavior are reviewed [organization-defined parameter].

NIST SP 800-53 Rev 5 control PL-8.1 (Defense in Depth) summarizes the requirements for this control: PL-8.1 · Defense in Depth Control Statement: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined parameter] to [organization-defined parameter] ; and (b) Ensures that the allocated controls operate in a coordinated and mutually reinforcing manner. Supplemental Guidance: Design the security and privacy architectures for the system using a defense-in-depth approach that: (a) Allocates [organization-defined param

NIST SP 800-53 Rev 5 control PL-7 (Concept of Operations) summarizes the requirements for this control: PL-7 · Concept of Operations Control Statement: a. Develop a Concept of Operations (CONOPS) for the system describing how the organization intends to operate the system from the perspective of information security and privacy; and b. Review and update the CONOPS [organization-defined parameter]. Supplemental Guidance: a. Develop a Concept of Operations (CONOPS) for the system describing how the organization intends to operate the system from the perspective of information security and privacy;